

 An official website of the United States government [Here's how you know](#)



America's Cyber Defense Agency

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Cybersecurity Performance Goals 2.0 (CPG 2.0)

The CPGs 2.0 are voluntary practices with high-impact security actions that outline the highest-priority baseline that measures businesses and critical infrastructure owners of all sizes can take to protect themselves against cyber threats. They were developed based on CISA's operational data, research on the current threat landscape, and collaboration with government, industry groups, and private sector experts to receive input and feedback.

Govern (1)

Establish Cybersecurity Responsibilities (1.A) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishcybersecurityresponsibilities1a>>

Outcome:

- Roles, responsibilities, and authorities related to the organization's cybersecurity program are established, communicated, enforced, and aligned within the organization and external partners.

Risk Addressed:

- Lack of sufficient cybersecurity accountability, investment, or effectiveness.

Scope:

- C-suite personnel, critical section leadership, physical and cybersecurity personnel, third-party contractors, vendors, and suppliers

Recommended Action:

- All roles and responsibilities involving cybersecurity should be documented in an organization's cybersecurity policy. .
- Roles and responsibilities related to the cybersecurity policy and program are distributed across the organization. Third-party contractors can also be involved to assist with these activities.
- Ensure that legal and regulatory requirements regarding cybersecurity, including privacy, are implemented and managed.
- OT: Establish and maintain continuous collaboration between information technology (IT) and operational technology (OT) teams in order to streamline processes, enhance security measures, and boost operational effectiveness.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate

Manage Cybersecurity Oversight (1.B) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#managecybersecurityoversight1b>>

Outcome:

- The organization's cybersecurity risk management strategy, expectations, and policies are established.

Risk Addressed:

- Insufficient cybersecurity policies and procedures/practices that can manage cybersecurity risk for the organization's technologies and processes.

Scope:

- Organization-wide.

Recommended Action:

- Policies for managing the cybersecurity program are reviewed at least annually, updated when changes are applied, communicated, and enforced to reflect changes in requirements, risks, threats, technology, and organizational mission. Policies are established based on the organization and its cybersecurity strategy, and priorities are communicated and enforced. It is recommended that organizational governance encompass the policies, procedures, and processes necessary to manage the organization's regulatory, legal, risk, environmental, and operational obligations.
- OT: OT-specific policies and procedures should consider the limitations of the existing IT cybersecurity program to identify priorities for critical operational functions, OT-specific security concerns, and compensating controls.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate

Manage Incident Response Plans (1.C) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#manageincidentresponseplans1c>>

Outcome:

- Identify improvements by practicing cybersecurity and incident response (IR) plans to maintain and update the organization's cybersecurity program.

Risk Addressed:

- Inability to quickly and effectively isolate, contain, eradicate, remediate, and communicate about cybersecurity incidents.

Scope:

- Organization-wide.

Recommended Action:

- Organizations develop, maintain, update, and regularly exercise IR plans for common and organizationally specific (e.g., by sector, locality) threat scenarios and tactics, techniques, and procedures (TTPs). Ensure drills are realistic and include all relevant stakeholders. IR plans should be reviewed and drilled, at a minimum, on an annual basis.
- OT: OT IR plans account for specific safety and containment considerations, which differ from existing IT plans and priorities.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate

Supply Chain Incident Reporting & Vulnerability Disclosure (1.D)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#supplychainincidentreportingvulnerabilitydisclosure1d>>

Outcome:

- Organizations more rapidly learn about and respond to known incidents or breaches across vendors and service providers

Risk Addressed:

- Insufficient cybersecurity supply chain risk management (C-SCRM) practices that cannot securely support the organization's technologies and processes.

Scope:

- Third-party vendors and service providers.

Recommended Action:

- Procurement documents and contracts, such as service-level agreements (SLAs), stipulate that vendors and/or service providers notify the procuring customer of security incidents and vulnerabilities within a risk-informed time frame as determined by the organization.
- OT: Organizations with OT assets need to document and track serial numbers, checksums, digital certificates/signatures, or other identifying features that can enable them to verify the authenticity of vendor-provided OT hardware, software and firmware.

Cost:

- Moderate

Impact:

- Moderate

Ease of Implementation

- Complex

Manage Risks from Managed Service Providers (1.E)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#managerrisksfrommanagedserviceproviders1e>>

Outcome:

- The risks posed by a managed service provider (MSP) are identified, recorded, assessed, prioritized, monitored, and updated over the course of the relationship.

Risk Addressed:

- Adversaries can exploit vulnerabilities by abusing trusted third-party relationships.

Scope:

- Service providers that remotely manage an organization's IT and/or OT infrastructure, cybersecurity processes, and/or other related business operations.

Recommended Action:

- Develop and maintain an understanding of the services, including the security products provided by MSPs. Understand contractual agreements and proactively address any security gaps that fall outside the scope of the contract. For example: contracts should detail how and when MSPs notify the customer of an incident affecting the customer's environment.

Cost:

- Moderate

Impact:

- Moderate

Ease of Implementation

- Complex

Identify (2)

Manage Organizational Assets (2.A) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#manageorganizationalassets2a>>

Outcome:

- A maintained asset inventory to improve cybersecurity resilience by reducing downtime, aiding recovery, bolstering defenses, and improving preparedness.

Risk Addressed:

- Adversaries might use computer accessories, networking hardware, or other devices as entry points to infiltrate systems or networks.

Scope:

- Data, hardware, software, systems, facilities, personnel.

Recommended Action:

- Maintain a regularly updated inventory of all organizational assets (i.e., data, hardware, software, systems, facilities, and personnel).
- IT and OT assets determined to be critical for business or operational functions should be updated on a more frequent basis.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate

Mitigate Known Vulnerabilities (2.B) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#mitigateknownvulnerabilities2b>>

Outcome:

- Reduced likelihood of threat actors exploiting known vulnerabilities to breach organizational networks.

Risk Addressed:

- Adversaries frequently target unpatched and misconfigured systems, particularly those exposed to the internet. Adversaries often leverage software vulnerabilities, temporary malfunctions, or configuration errors to gain initial access to a network.

Scope:

- All organizational assets, to include those that face the internet.

Recommended Action:

- Implement a vulnerability management program to patch and mitigate misconfigured software in a timely manner.
- Monitor risk response progress through tools such as plan of action and milestones (POA&M), risk registers, and risk detail reports.
- Document potential risks of proposed changes and provide rollback guidance. Assign responsibilities and ensure procedures are followed for processing and responding to cybersecurity threats, vulnerabilities, or incident disclosures from various stakeholders. Incorporate compensating security controls (e.g., defense in depth) to address legacy systems, where possible.
- OT: For assets where patching is either not possible or may substantially compromise availability or safety, compensating controls are applied (e.g., segmentation, monitoring) and recorded. Sufficient controls either make the asset inaccessible from the public internet or reduce the ability of threat actors to exploit the vulnerabilities in these assets.

Cost:

- High

Impact:

- High

Ease of Implementation

- Complex

Obtain Independent Validation of Cybersecurity Controls (2.C)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2->

0#obtainindependentvalidationofcybersecuritycontrols2c>

Outcome:

- Validate that implemented security controls are properly configured and working as intended

Risk Addressed:

- Reduce the risk of gaps in cyber defenses or overconfidence in existing protections.

Scope:

- Organizational assets and networks.

Recommended Action:

- Organizations regularly engage third-party cybersecurity experts to validate their defenses through various exercises, such as penetration tests, bug bounties, incident simulations, and table-top exercises. These tests, both announced and unannounced, assess the ability of adversaries to infiltrate and move laterally within the network, targeting critical systems. Ensure findings from these tests are addressed.

Cost:

- High

Impact:

- High

Ease of Implementation

- Complex

Maintain Vulnerability Disclosure/Reporting Process (2.D)

<[https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-](https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#maintainvulnerabilitydisclosurereportingprocess2d)

0#maintainvulnerabilitydisclosurereportingprocess2d>

Outcome:

- Organizations more rapidly learn about vulnerabilities or weaknesses.

Risk Addressed:

- Reporting known security vulnerabilities in a company's software, networks, devices, and systems directly to the organization allows them to address and mitigate these vulnerabilities before adversaries can exploit them.

Scope:

- All public-facing assets and web domains.

Recommended Action:

- Organizations maintain a public, easily discoverable method for individuals to notify (e.g., via email address or web form) organizations' security teams of vulnerable, misconfigured, or otherwise exploitable assets. Valid submissions are acknowledged and responded to in a timely manner, taking into account the completeness and complexity of the vulnerability. Validated and exploitable weaknesses are mitigated consistent with their severity.
- Individuals who identify and report vulnerabilities discovered in good faith should be protected under safe harbor rules. Safe harbor rules are provisions in law that protect individuals or entities from penalties under certain conditions.
- Security.txt files that conform with the recommendations in RFC 9116 are one commonly utilized standard to streamline vulnerability notifications. This should be applied to all public-facing web domains.

Cost:

- Low

Impact:

- Low

Ease of Implementation

- Moderate

Document Network Topology (2.E) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#documentnetworktopology2e>>

Outcome:

- More efficiently and effectively respond to incidents and maintain service continuity.

Risk Addressed:

- Incomplete or inaccurate understanding of network topology inhibits effective incident response and recovery.

Scope:

- Organizational networks.

Recommended Action:

- Organizations maintain accurate documentation describing current network topology and relevant information across all IT and OT networks. Network reviews should be performed and tracked on an annual basis and documentation updated when network topology changes are made.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate

Protect (3)

Changing Default Passwords (3.A) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#changingdefaultpasswords3a>>

2-0-cpg-2-0#changingdefaultpasswords3a>

Outcome:

- Prevent threat actors from using default passwords to achieve initial access and move laterally in a network.

Risk Addressed:

- Adversaries might acquire and exploit default account credentials to gain initial access, maintain persistence, escalate privileges, or evade defenses.

Scope:

- Password-protected newly acquired and legacy IT and OT assets.

Recommended Action:

- Implement an organization-wide policy that requires changing default manufacturer passwords for all hardware, software, and firmware before connecting them to any internal or external network. This includes IT assets used in OT, such as OT administration web pages.
- If changing default passwords is not feasible (e.g., due to hard-coded passwords in control systems), document and implement appropriate compensating security controls and monitor logs for network traffic and login attempts on these devices.
- OT: Change default passwords on existing OT systems and establish a policy for changing default credentials on all new or future devices. This will reduce potential risk in the future if vulnerabilities change.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Simple

Establish Minimum Password Strength (3.B) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishminimumpasswordstrength3b>>

Outcome:

- Organizational passwords are harder for threat actors to guess or crack.

Risk Addressed:

- Adversaries use brute force techniques to crack passwords when unknown or hashes are obtained. They systematically guess using repetitive methods, either interacting with services to validate credentials or working offline with acquired data.

Scope:

- User account passwords.

Recommended Action:

- Organizations have a system-enforced policy to establish a minimum password strength, to include a password length of 16 or more characters for all password-protected IT assets and all OT assets, when technically feasible. Organizations should consider leveraging passphrases and password managers to make it easier for users to maintain sufficiently long passwords. In instances where minimum password lengths are not technically feasible, compensating controls are applied and recorded, and all login attempts to those assets are logged. Assets that cannot support passwords of sufficient strength are prioritized for upgrade or replacement.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Simple

Create Unique Credentials (3.C) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#createuniquecredentials3c>>

Outcome:

- Adversaries are unable to reuse compromised credentials to move laterally across the organization, particularly between IT and OT networks.

Risk Addressed:

- Adversaries can obtain and exploit account credentials to gain access, maintain persistence, escalate privileges, or evade defenses. These credentials can bypass network access controls for continuous access to remote systems and external services.

Scope:

- User accounts.

Recommended Action:

- Organizations create distinct and separate credentials for similar services and asset access across IT and OT networks. Users refrain from reusing passwords for their accounts, applications, and services. Additionally, system administrators and service/machine accounts have unique passwords that differ from those of regular user accounts.
- No universal non-person entity (NPE) account passwords should be deployed. If NPE devices are used, leverage different passwords for each.
- Role based accounts for IT and OT systems are utilized when possible.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Simple
-

Revoking Credentials for Departing Staff (3.D) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#revokingcredentialsfordepartingstaff3d>>

Outcome:

- Prevent unauthorized access to organizational accounts or resources by former staff.

Risk Addressed:

- Adversaries can exploit inactive accounts of former staff to evade detection.

Scope:

- Departing staff, who may include contractors, vendors, etc.

Recommended Action:

- Organizations should have a defined and enforced administrative process to off board staff (e.g., personnel, contractors, vendors). This process should include the return of all physical tokens and/or badges and the revocation of all access to systems and facilities.
- Review user access and disable accounts when inactive for a specified period (e.g., 30 days). Ideally this review is conducted using an automated process and preset policies implemented via script or platform feature.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate
-

Monitor Unsuccessful (Automated) Login Attempts (3.E)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#monitorunsuccessfulautomatedloginattempts3e>>

Outcome:

- Protect organizations from automated, credential-based attacks.

Risk Addressed:

- Adversaries might acquire and exploit default account credentials to gain access, maintain persistence, escalate privileges, or evade defenses.

Scope:

- Password-protected newly acquired and legacy IT and OT assets.

Recommended Action:

- All unsuccessful logins are captured and logged as directed by the organization's security policy. Security personnel are notified (e.g., by an alert) after a specific number of consecutive unsuccessful login attempts in a short period and a deviation from normal user behavior. This alert is logged and stored in the relevant security or ticketing system for retroactive analysis.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate

Implement Multi-factor Authentication (3.F) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#implementmultifactorauthentication3f>>

Outcome:

- Add a critical, additional layer of security to protect assets accounts.

Risk Addressed:

- Adversaries without prior knowledge of legitimate credentials might try commonly used passwords across various accounts to gain access. They might also systematically guess passwords using repetitive or iterative methods.

Scope:

- Organizational assets with remote access, such as workstations and human-machine interfaces (HMI), where safe and technically feasible.

Recommended Action:

- Organizations require MFA to access assets using the strongest available method, if MFA is available for that asset.
- MFA options sorted by strength, high to low, are as follows:
 1. Phishing-resistant MFA (e.g., FIDO/WebAuthn or public key infrastructure [PKI]-based—see CISA guidance in “Support Resources”).
 2. If phishing-resistant MFA is not available, then mobile app-based soft tokens (preferably push notification with number matching).
 3. MFA via short message service (SMS) or voice is only used when no other options are possible.
- IT: All IT accounts leverage MFA to access organizational resources. Prioritize accounts with highest risk, such as privileged administrative accounts for key IT systems.
- OT: MFA is enabled on all accounts and systems that can be accessed remotely, including vendors/maintenance accounts, remotely accessible user and engineering workstations, and remotely accessible HMIs when available. If MFA is not available, remove remote access, introduce additional segmentation steps, and prioritize credential management.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate
-

Administrators Maintain Separate User and Privileged Accounts (3.G)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#administratorsmaintainseparateuserandprivilegedaccounts3g>>

Outcome:

- Make it harder for threat actors to gain access to administrator or privileged accounts, even if common user accounts are compromised.

Risk Addressed:

- Adversaries might obtain and exploit credentials from existing accounts for initial access, persistence, privilege escalation, or defense evasion. These compromised credentials can bypass network access controls and provide continuous access to remote systems and external services.

Scope:

- Organizational assets, where safe and technically feasible.

Recommended Action:

- User accounts do not have administrator privileges. Administrators maintain separate user accounts for activities unrelated to their admin role, such as business email and web browsing. Privileges are re-evaluated on a recurring basis to validate continued need for a given set of permissions.
- Separation of duties is maintained by distributing responsibilities across multiple individuals or roles to reduce the risk of unauthorized actions, errors, or fraud.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Simple
-

Implement the Principles of Least Privilege (3.H) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#implementtheprinciplesofleastprivilege3h>>

Outcome:

- Minimizes unauthorized access to systems, data, and processes, reduces human error, and prevents malicious actions; helping ensure the organization's sensitive information and critical assets remain protected.

Risk Addressed:

- Unauthorized access to network resources and the potential for adversaries to move across systems undetected, compromising sensitive data and critical systems.

Scope:

- All organizational accounts.

Recommended Action:

- All user accounts, system roles, and processes operate with the minimum privileges necessary to perform their tasks.
- Perform quarterly reviews of access permissions and role assignments to verify compliance with established policies.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Simple
-

Implement Logical/Physical Network Segmentation (3.I)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#implementlogicalphysicalnetworksegmentation3i>>

Outcome:

- Limiting the impact(s) of a potential breach and preventing adversaries from accessing sensitive data, spaces, and/or critical infrastructure.

Risk Addressed:

- If a network is compromised by an unauthorized user, a securely segregated network can contain malicious occurrences.

Scope:

- Organizational assets, where safe and technically feasible.

Recommended Action:

- Routers are placed between networks to create boundaries, increase the number of broadcast domains, and effectively filter users' broadcast traffic. These boundaries can be used to contain security breaches by restricting traffic to separate segments and can even shut down segments of the network during an intrusion, restricting adversary access.
- OT: When applicable, physically segment OT enclaves (e.g., data diodes).

Cost:

- High

Impact:

- High

Ease of Implementation

- Complex
-

Implement Cybersecurity Training (3.J) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#implementcybersecuritytraining3j>>

Outcome:

- Organizational users learn and perform more secure behaviors.

Risk Addressed:

- Train users on recognizing access or manipulation attempts by adversaries to lower the risk of successful spear phishing, social engineering, and other techniques that involve user interaction.

Scope:

- All employees, contractors, partners, suppliers, providers, and other users of the organization's non-public resources.

Recommended Action:

- New employees receive initial cybersecurity training prior to accessing computer systems.
- Provide at least annual cybersecurity training for all organizational users to train personnel in recognizing social engineering attempts and other common attacks, reporting attacks and suspicious activity, complying with acceptable use policies, and performing basic cyber hygiene tasks (e.g., choosing passwords, protecting credentials).
- Identify the specialized roles within the organization that require additional cybersecurity training, such as physical and cybersecurity personnel, system administrators, finance personnel, senior leadership, and anyone with access to business-critical data. Provide role-based cybersecurity training to all those in specialized roles, including contractors, partners, suppliers, and other third parties.
- OT: Personnel should receive security awareness and training for the OT environment. In addition, organizations should identify, document, and train all personnel who have significant OT roles and responsibilities.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate
-

Utilize Strong Encryption (3.K) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#utilizestrongencryption3k>>

Outcome:

- Encryption is deployed to maintain confidentiality and integrity of sensitive data across the organization's network to protect from unauthorized access.

Risk Addressed:

- Adversaries can position themselves between networked devices to enable network sniffing and data manipulation, or to steal operational data from environments for personal gain or future operations.

Scope:

- Passwords, credentials, secrets, and other sensitive or controlled information.

Recommended Action:

- Use encryption, digital signatures, and cryptographic hashes to protect the confidentiality and integrity of network communications.
- Identify critical electronic file types and data to protect while in transit and at rest. This may include personally identifiable information and sensitive, proprietary or trade secret information (e.g., PLC program code, robot programs, computer-aided drafting [CAD] or computer-aided manufacturing [MAC] files, operating manuals and documentation, electrical diagrams, network diagrams, historical production data).

- Sensitive data, including passwords, are not electronically stored in plaintext anywhere in the organization and can only be accessed by authenticated and authorized users. Credentials are stored in a secure manner, such as with a credential/password manager.
- OT: Use encryption for external connections and where latency issues would not result in an impact to operations.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Complex
-

Enable Email Security (3.L) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#enableemailsecurity3l>>

Outcome:

- Reduce risk from common email-based threats, such as spoofing, phishing, and interception.

Risk Addressed:

- Adversaries might send victims emails with malicious attachments or links, aiming to run harmful code on their systems. They can also conduct phishing through third-party services like social media platforms.

Scope:

- All organizational email infrastructure.

Recommended Action:

- On all corporate email infrastructure (1) STARTTLS is enabled, (2) Sender Policy Framework (SPF) and DomainKeys Identified Mail (DKIM) are enabled, and (3) Domain-based Message Authentication, Reporting, and Conformance (DMARC) is enabled and set to “reject.”

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate
-

Disable Autorun & Macros By Default (3.M) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#disableautorunmacrosbydefault3m>>

Outcome:

- Reduce the risk from embedded macros and similar executable code.

Risk Addressed:

- Adversaries rely on users to open malicious files to execute code. Social engineering tactics could be used to convince users to open such files.

Scope:

- All organizational assets.

Recommended Action:

- A system-enforced policy that disables macros, or similar embedded code, by default on all devices to prevent automatic execution of code or applications.
- If macros must be enabled in specific circumstances, establish a policy for authorized users to request that macros are enabled on specific assets.

- Autorun, or AutoPlay, should also be disabled by default to prevent unintentional code execution from sources such as USB or optical drives.

Cost:

- Low

Impact:

- Moderate

Ease of Implementation

- Simple
-

Establish Change Management Processes (3.N) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishchangemanagementprocesses3n>>

Outcome:

- Policies and procedures exist to manage system changes and configurations.

Risk Addressed:

- Delayed, insufficient, or incomplete ability to maintain or restore functionality of critical devices and service operations.

Scope:

- Organizational assets.

Recommended Action:

- Implement policies and processes to develop, document, and maintain secure change management for technology platforms and enforce configuration restrictions to prevent unauthorized changes.
- Technical configuration change control processes are in place, prohibiting unauthorized changes unless approved. Test and document proposed changes in a non-production environment and analyze potential security impacts before implementation.

- OT: Implement limited functionality by permitting only specific functions, protocols, and services necessary for OT operations.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Complex
-

Maintain System Backups & Restoration Ability (3.O)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#maintainsystembackupsrestorationability3o>>

Outcome:

- Organizations reduce data loss and service disruption risks while efficiently managing, responding to, and recovering from incidents to maintain continuous service delivery.

Risk Addressed:

- Adversaries can disrupt critical systems to halt the delivery of products or services. They can delete data and disable recovery services, preventing system recovery. Adversaries may turn off services designed to aid in recovering a corrupted system.

Scope:

- Organizational assets necessary for business operations.

Recommended Action:

- Develop a list of all maintained backups, including installation media, license keys, configuration information, and backup retention period of the information.

- Back up critical operations systems in near-real-time, and frequently back up all systems necessary for operations on a regular schedule consistent with the needs of the organization.
- Securely store backups offsite and offline. Test backups and recovery on a recurring basis, no less than once per year.
- Before initiating restoration, validate the integrity of backups and other assets intended for restoration. This verification process is to ensure that data is intact, accurate, and reliable, minimizing the risk of data corruption during the restoration process.
- Check restoration assets for indicators of compromise, file corruption, and other integrity issues before use.
- Regularly test backup information to verify media reliability and information integrity.
- OT: Stored information for OT assets includes, at a minimum, device configurations, roles, engineering drawings, and tools.

Cost:

- High

Impact:

- High

Ease of Implementation

- Moderate
-

Maintain Hardware & Software Approval Process (3.P)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#maintainhardwaresoftwareapprovalprocess3p>>

Outcome:

- Increase visibility into deployed technology assets and reduce the likelihood of breach by users installing unapproved hardware, firmware, or software.

Risk Addressed:

- Adversaries can manipulate products or delivery mechanisms before they reach final users and attempt data or system compromise. They can target devices that move across industrial control systems and production networks.

Scope:

- Organizational assets.

Recommended Action:

- Implement an administrative policy and process that requires review, testing, and approval before new hardware, firmware, or software is installed or deployed.
- Organizations maintain a list of approved hardware, firmware, and software that includes specification of approved versions, when technically feasible.
- OT: Consider additional requirements for organizations with OT environments when deploying patches and updates. This includes testing and validation to ensure they do not impact operational capabilities or safety.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate

Maintain Log Collection & Storage (3.Q) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#maintainlogcollectionstorage3q>>

Outcome:

- Enhance visibility to detect and respond to cyber incidents while ensuring security logs are protected from unauthorized access and tampering.

Risk Addressed:

- Delayed, insufficient, or incomplete ability to detect and respond to potential cyber incidents

Scope:

- Organizational assets on all assets, where safe and technically feasible.

Recommended Action:

- Administrative and security-focused logs (e.g., operating systems, applications, and services; intrusion detection systems/intrusion prevention systems; firewalls; data loss prevention; virtual private networks) are collected and stored for use in both detection and incident response activities (e.g., forensics).
- Logs are stored in a central system, such as a security information and event management tool or central database and can only be accessed or modified by authorized and authenticated users. Logs are stored for a duration informed by risk or pertinent regulatory guidelines.
- Security teams are notified when a critical log function is disabled.
- OT: For OT assets where logs are non-standard or not available, network traffic and communications between those assets and other assets is collected.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate

Prohibit Connection of Unauthorized Devices (3.R) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#prohibitconnectionofunauthorizeddevices3r>>

Outcome:

- Prevent malicious actors from achieving initial access or data exfiltration via unauthorized portable media devices.

Risk Addressed:

- Adversaries might infiltrate systems, including disconnected or air-gapped networks, by copying malware to removable media such as USB drives.

Scope:

- Organizational assets.

Recommended Action:

- Organizations maintain policies and processes to ensure that unauthorized media and hardware are not connected to IT and OT assets, such as limiting use of USB devices and removable media.
- OT: When feasible, establish procedures to remove, disable, or otherwise secure physical ports to prevent the connection of unauthorized devices or establish procedures for granting access through approved exceptions.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Complex

Secure Internet Facing Devices (3.S) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#secureinternetfacingdevices3s>>

Outcome:

- Unauthorized users cannot gain an initial system foothold by exploiting known weaknesses in internet-facing assets.

Risk Addressed:

- Adversaries might exploit weaknesses in internet-facing hosts or systems to gain initial network access, targeting software bugs, temporary glitches, or misconfigurations.

Scope:

- Organizational assets on the public internet.

Recommended Action:

- Minimize internet-facing assets whenever possible. Prioritize keeping software current with timely patches and updates. If unable to apply updates, consider removing that asset, or implement compensating controls to prevent common forms of exploitation. These controls may include network segmentation or firewalls.
- All operating system applications, software and network protocols that are not necessary for mission-critical applications are disabled on internet-facing assets.
- Network management interfaces (NMI's) should never be exposed to the public internet and should only be accessible from within enterprise networks.
- Logically segment enterprise networks and production networks, including cloud-based platforms, according to trust boundaries and platform types (e.g., IT, IoT, OT, mobile, guests), and only permit required communications between segments.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Complex

Detect (4)

Establish Malicious Code Detection (4.A) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishmaliciouscodedetection4a>>

Outcome:

- Enables early threat identification, strengthens system integrity, provides insights for faster remediation, and minimizes downtime.

Risk Addressed:

- Malicious software can involve payloads, droppers, backdoors, etc. Adversaries use malware to control remote machines, evade defenses, and execute post-compromise actions.

Scope:

- Organization-wide.

Recommended Action:

- Implement signature-based mechanisms (relying on known patterns or signatures of malicious code used by antivirus software to identify and block threats) and non-signature-based mechanisms (focusing behavior, heuristics, or anomalies) to detect and eradicate malicious code at system endpoints. Ensure antivirus software is updated, active, and configured to automatically scan emails and removable media (e.g., flash drives) for ransomware and other malware.
- OT: Using antivirus software with OT devices may require special practices, including compatibility checks, change management, and performance impact metrics. These practices should be employed to test new signatures and new versions of malicious code protection solutions.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate
-

Identify Adverse Events (4.B) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#identifyadverseevents4b>>

Outcome:

- Organizations can identify adverse security events.

Risk Addressed:

- Initial access, privilege escalation, and lateral movement.

Scope:

- Organization-wide.

Recommended Action:

- Ensure the organization has defined clear criteria and processes for adverse events. If an adverse event is suspected, follow the protocol outlined in the incident response plan to escalate the situation.
- Automate event information analysis as much as possible to accelerate the investigative timeline for managing suspected adverse events. This will give analysts the time and capacity to mitigate these events effectively.
- Conduct analyst role-specific training on the proper protocols and procedures to follow in the event of a suspected cyber incident.
- OT: Organizations should account for OT-specific events and anomalies in their processes and environments. It's important to recognize that certain tools and alerts for behaviors or events that could indicate an intrusion might actually be normal within the OT environment.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Complex
-

Respond (5)

Establish Incident Communication Procedures (5.A)

<<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishincidentcommunicationprocedures5a>>

Outcome:

- Coordinate crisis communication methods between internal and external organization partners and critical suppliers.

Risk Addressed:

- Without established communication procedures, incidents can disrupt coordination among response teams, slowing incident resolution, increasing downtime, and amplifying overall damage.

Scope:

- Organization-wide.

Recommended Action:

- Design a communications plan that identifies stakeholders and mechanisms for coordination and communications during an incident.
- Collaborate with stakeholders and securely share information consistent with response plans and information-sharing agreements. Priorities for sharing information include preventing the spread of infections to other systems and networks.
- Regularly update senior leadership on the status of major incidents.
- Notify human resources when malicious insider activity occurs.
- Establish and follow media communications procedures for incident response that comply with the organization's policies on media interaction and information disclosure.

Cost:

- Low

Impact:

- High

Ease of Implementation

- Moderate
-

Establish Incident Reporting Procedures (5.B) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#establishincidentreportingprocedures5b>>

Outcome:

- CISA and other organizations are better able to provide assistance or understand the broader scope of a cyber incident.

Risk Addressed:

- Without timely incident reporting, CISA and other groups are less able to assist affected organizations and lack critical insight into the broader threat landscape, such as whether a broader attack is occurring against a specific sector.

Scope:

- Organization-wide.

Recommended Action:

- Organizations maintain policy and procedures on to whom and how to report all confirmed cybersecurity incidents to appropriate external entities (e.g., state/federal regulators or sector risk management agencies [SRMAs] as required, information sharing and analysis centers [ISACs], information sharing and analysis organizations [ISAOs], and CISA).
- Known incidents are reported to CISA as well as other necessary parties within time frames directed by applicable regulatory guidance or in the absence of guidance, as soon as safely feasible.

Cost:

- Moderate

Impact:

- High

Ease of Implementation

- Moderate

Recover (6)

Incident Planning and Preparedness (6.A) <<https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#incidentplanningandpreparedness6a>>

CISA's CPGs are not comprehensive. They do not identify all the cybersecurity practices needed to protect national and economic security and public health and safety. They capture a core set of cybersecurity practices with known risk-reduction value broadly applicable across sectors.

CISA Product Survey

We welcome your feedback.

CISA PRODUCT SURVEY

[Return to top <https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#top>](https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0#top)

Topics <https://www.cisa.gov/topics> **Spotlight** <https://www.cisa.gov/spotlight>

Resources & Tools <https://www.cisa.gov/resources-tools>

News & Events <https://www.cisa.gov/news-events> **Careers** <https://www.cisa.gov/careers>

About <https://www.cisa.gov/about>

CISA Central

1-844-Say-CISA contact@cisa.dhs.gov

CISA.gov
An official website of the U.S. Department of Homeland Security

About CISA <https://www.cisa.gov/about>	Budget and Performance <https://www.dhs.gov/performance-financial-reports>	DHS.gov <https://www.dhs.gov/>
FOIA Requests <https://www.dhs.gov/foia>	No FEAR Act <https://www.cisa.gov/no-fear-act>	Office of Inspector General <https://www.oig.dhs.gov/>
Privacy Policy <https://www.cisa.gov/privacy-policy>	Subscribe	The White House <https://www.whitehouse.gov/>
USA.gov <https://www.usa.gov/>	Website Feedback <https://www.cisa.gov/forms/feedback>	